



ARKA HEALTH, INC.

SECURE SOFTWARE DEVELOPMENT & CHANGE MANAGEMENT POLICY

Integrity controls, 45 C.F.R. § 164.312(c); change management, SOC 2 CC8.1

ARKA-SEC-010 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-010
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE AND SCOPE

This Policy governs the development, review, testing, approval, deployment, and emergency modification of all software constituting or supporting the ARKA Platform, in order to preserve the integrity of systems processing ePHI and to ensure that changes are authorized, tested, documented, and reversible.

2. SECURE DEVELOPMENT STANDARDS

1. **Branch protection and review.** All changes enter production exclusively through version-controlled pull requests; direct commits to protected branches and direct modification of production infrastructure are technically disabled. Each pull request requires at least one approving review by someone other than its author; while the engineering team numbers fewer than three, the compensating control is a mandatory self-review checklist plus full CI gating, documented in the pull request.
2. **CI quality gates.** Merges are blocked unless automated checks pass: type checking, unit and compliance test suites, lint rules (including the platform's scope-boundary and CDS card-linting checks), dependency vulnerability audit, and secret-scanning. High or critical dependency vulnerabilities block release; lower severities are triaged within thirty (30) days.
3. **Secure coding.** Engineering personnel follow OWASP guidance for the platform's stack; input validation is enforced at API boundaries with schema validation; authorization checks are server-side; and security-relevant utilities (encryption, authentication, audit logging) are centralized rather than re-implemented.
4. **No PHI in development.** Production data shall not be copied to development, test, staging, or demonstration environments. Seed and fixture data are synthetic (ARKA-DEMO-001). CI guards fail the build where demonstration fixtures import production data sources.
5. **Static analysis of AI-assisted code.** Code produced with generative tooling is subject to the same review, testing, and provenance standards as human-authored code; no such tooling is granted access to production credentials or ePHI.

3. CHANGE CLASSES AND APPROVAL

Class	Definition	Approval
Standard	Routine application changes within existing architecture	Peer review + passing CI
Significant	New data stores, new third-party integrations, authentication or encryption changes, schema changes affecting ePHI	Security Officer sign-off recorded in the change record; targeted risk re-assessment where ARKA-SEC-002, § 3 applies
Emergency	Hotfix required to restore service or close an actively exploited vulnerability	Deploy first where necessary; retrospective review and full documentation within two (2) business days

4. DEPLOYMENT AND ROLLBACK

Deployments are executed by automated pipeline from tagged, immutable artifacts; the identity of the deployer, the artifact hash, and the associated change records are logged (ARKA-SEC-005). Every production deployment must be reversible by redeployment of the prior artifact; schema migrations require a tested rollback or roll-forward plan before merge. Release notes for Customer-visible changes are maintained, and changes affecting clinical-content behavior of ARKA-CLIN additionally follow the clinical sign-off log maintained in the platform repository.

5. VULNERABILITY MANAGEMENT

In addition to continuous dependency scanning in CI: production infrastructure undergoes vulnerability scanning at least every six (6) months; an independent penetration test is performed at least every twelve (12) months and after material architectural change, with findings remediated on the following schedule — Critical: ten (10) days; High: thirty (30) days; Medium: ninety (90) days; Low: at next planned release — or formally risk-accepted under ARKA-GOV-001, § 7. A coordinated vulnerability-disclosure channel (security@getarka.health) is published on the Company website.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026